Individual Contribution Statement - Trieu Ngoc Van Anh

Course	Introduction to Information Security 2026-2027
Class / Group	N05 / Group 05
Name	Trieu Ngoc Van Anh
Student ID	524H0005
Primary responsibility	Threat modeling and access-control design
Project	Design, Implement, and Audit Secure Access Control - University Records System (UniRecords)

1. Tasks completed

- **Threat model (Task 1):** identified the assets (A1-A8), users and trust boundaries TB1-TB3, drew the system and data-flow diagram (`docs/dfd.svg`) and wrote the threat-model table with twelve threats, including the eight required aspects plus CSRF, self-service abuse and password-reset takeover.
- **Security requirements:** derived SR1-SR16 and traced each requirement to the threats and to the tests that verify it (report Appendix C).
- **Access-control policy (Task 2):** designed the access-control matrix for the five roles and the explanation of default deny, least privilege, separation of duties, role conflicts, multiple roles, ownership and course-assignment checks (report Chapter 4).
- **Policy data:** defined the permissions, their OWN / ASSIGNED / ALL scopes and the three role conflicts in `database/seed-data.sql` (`permissions`, `role_permissions`, `role_conflicts`).
- **Security review (Task 5):** reviewed the suggested areas against the implementation and wrote the eight remaining limitations with likelihood, impact, risk and recommendation (report Chapter 8).
- **Report:** wrote Chapters 1, 3, 4 and 8, the abstract and the conclusion.
- **Demo video:** segment 1 (group and system introduction, three unauthorized operations).

2. Repository commits

My commits are recorded in the group repository: **https://github.com/duongtranquockhanhwork/Project-for-user-roles** (commit author **Trieu Ngoc Van Anh**). They can be listed with `git log --author="Trieu Ngoc Van Anh" --date=short` or on the repository's *Commits* page. The first version of the project was imported into the repository by Duong Tran Quoc Khanh; my own commits follow in the repository history.

3. Technical decisions made

- **Scoped permissions instead of one role per course.** A permission carries a scope (OWN, ASSIGNED, ALL), so a lecturer's access to "assigned courses" needs no extra roles. This avoids role explosion.
- **Union of permissions for multiple roles, without widening scopes.** The teaching assistant `ta01` (Student + Lecturer) shows this: they read their own grades and grade their own class, but never grade themselves.
- **Three role conflicts for separation of duties:** ADMIN+AUDITOR, LECTURER+REGISTRAR and STUDENT+REGISTRAR, enforced when roles are assigned and again by a database trigger.
- **Administrator without academic access, and dual control.** An administrator cannot change their own roles, so any additional academic access requires a second administrator.

- **Self-registration always creates a new STUDENT profile** and can never claim an existing record (threat TH11).
- **Deny-override for renaming:** students and lecturers may rename themselves, but anyone who also holds ADMIN, AUDITOR or REGISTRAR may not.

4. Problems solved

- **Requirement to let administrators read passwords.** I analysed this request against the assignment rule that passwords are never stored in plaintext, and against the ADMIN/AUDITOR separation. We replaced it with an administrator-approved reset in which a one-time temporary password is shown only to the requester (threat TH12).
- **"One lecturer per class" conflicted with the original seed data**, which gave NW301 two lecturers. I moved the multi-role user `ta01` to the new class SE202, which keeps the self-grading demonstration while respecting the rule.
- **Report length.** The matrix and the threat table grew with every new feature. I merged equivalent matrix rows and condensed the explanations, so that the main body stays at 10 pages.

5. Approximate hours worked

[to be filled] hours in total (week 1: [ ] h, week 2: [ ] h, week 3: [ ] h).

6. Contributions of the other members

- **Duong Tran Quoc Khanh** implemented authentication, sessions, CSRF, the authorization layer, the application routes and user interface, self-registration, classes and grading, account self-service and the password-reset workflow, and wrote report Chapters 2 and 5.
- **Nguyen Vo Thanh Tu** built the database schema, the least-privilege grants, the guard triggers and the hash-chained audit log, wrote the 58 automated tests and the evidence capture, and wrote report Chapters 6 and 7 and the appendices.

7. Review of the complete submission

I reviewed the complete submission (source code, database scripts, tests, evidence, report and demo video) and agree with its content.

Date: ____ / ____ / 2026

Signature: _____

Trieu Ngoc Van Anh (524H0005)